

Adaptive Evasion Reframed: Tool Selection, Not Protocol Generation

The Correction

The gap is **NOT** protocol generation. It's:

1. **EDR/AV identification** — Detect if this host runs CrowdStrike, Sentinel, or legacy McAfee
2. **SOC posture measurement** — Send sacrificial implant, measure response speed and technique
3. **C2 arsenal selection** — Swap between pre-built channels (AWS SQS, OneDrive, GDrive, DNS, HTTPS APIs)
4. **Tactic selection** — Based on detected EDR + measured SOC speed, choose dormancy / evasion escalation / exfiltration

None of this requires inventing new protocols. It all exists in today's malware toolkit. The gap is **orchestration**: connecting these pieces in real-time without human instruction.

Operational Model: Foundry-Fed Implants + Sacrificial Probing

Layer 1: Defensive Tool Identification

The malware **can identify installed EDR/AV** by:

```
Technique 1: Behavioral signature detection
- CrowdStrike Falcon:
  * Process name "CSFalconContainer"
  * Registry keys at HKLM\SYSTEM\CurrentControlSet\Services\CSFalconService
  * Telemetry beacons to *.falcon.crowdstrike.com

- Microsoft Defender:
  * Process "MsMpEng.exe" or "NisSvc"
  * Registry at HKLM\SOFTWARE\Microsoft\Windows Defender
  * WMI classes like "SecurityCenter2"

- McAfee (legacy):
  * "McShield.exe" or similar
  * Registry at HKLM\SOFTWARE\McAfee
  * File system monitoring only (no behavioral)
```

```
Technique 2: Probing responses
```

- Attempt a known Falcon-detectable behavior (e.g., LSASS access)
- Measure latency of detection and blocking
- CrowdStrike: <5 seconds | Sentinel: 10-30 seconds | McAfee: >60 seconds or no response

Technique 3: SIEM / C2 visibility inference

- If C2 callbacks are blocked, infer strong egress filtering (likely Tier 1)
- If C2 callbacks succeed, infer weak egress filtering (likely Tier 5)
- If C2 is delayed but not blocked, infer analytics-based detection (likely Tier 2-3)

Feasibility: HIGH — All of these are detectable without SIEM compromise.

Layer 2: Sacrificial Implant Reconnaissance

The malware **doesn't risk the primary implant**. Instead:

```
def probe_soc_capability():
    """Deploy sacrificial implants to measure SOC response"""

    # Foundry provides multiple implant variants
    implant_variants = [
        ImplantVariant.OBVIOUS_BEACON,      # Simple HTTP callback
        ImplantVariant.OBVIOUS_FILECREATE,   # Drop marker file
        ImplantVariant.OBVIOUS_REGISTRY,     # Write registry key
        ImplantVariant.SUBTLE_TIMING,        # Random beacon intervals
        ImplantVariant.SUBTLE_OBFUSCATION,   # Base64-encoded C2
    ]

    for variant in implant_variants:
        # Deploy to low-value host (not critical infrastructure)
        target = select_low_value_host()

        # Send sacrificial implant via different C2 channel
        # (one that's NOT used by primary campaign)
        c2_channel = select_unused_channel()

        # Measure response:
        response_time = measure_detection_latency(target, variant)
        isolation_time = measure_network_isolation_latency(target)
        hunt_intensity = measure_siem_correlation_activity()

        # Log results
        log_soc_response(target, variant, response_time, isolation_time,
            hunt_intensity)

    # Aggregate: What's the SOC's detection profile?
    soc_level = classify_from_responses(responses)
    return soc_level, optimal_evasion_tactics(soc_level)
```

The Primary Malware Observes and Learns: - Variant 1 (obvious beacon) → Detected in 15 minutes → CrowdStrike Falcon - Variant 2 (file create) → Detected in 2 hours → Managed EDR - Variant 3 (registry write) → Not detected → Legacy AV - Variant 4 (subtle timing) → Detected in 20 minutes → Behavioral analytics active

Conclusion: Tier 2 SOC with CrowdStrike + behavioral analytics + 2h response time

Response Strategy: Swap to slow C2 (AWS SQS with 6h beacon intervals), avoid registry writes, minimize behavioral deviation

Layer 3: C2 Arsenal Selection

The foundry has already built multiple stealth C2 channels:

```
Exists Today (from framework):
✓ C2 via legitimate cloud services (AWS, OneDrive, GDrive)
✓ Domain fronting / CDN abuse
✓ Polymorphic timing
✓ Dynamic C2 rotation (PROMPTSPY)

Pre-built in Foundry Arsenal:
✓ AWS SQS command queue (read from queue, write to queue)
✓ OneDrive GraphQL API (exfil via OneDrive file upload)
✓ GDrive API (command channel via shared drive folder)
✓ GitHub API (status updates via repo issues, commands via gist)
✓ DNS CNAME tunneling (commands in DNS responses)
✓ HTTPS to legitimate CDN (CloudFlare, Akamai fronting)
✓ SMTP (exfil via mail service)
✓ S3 bucket (commands via object uploads, exfil via download)
✓ Azure Blob Storage (similar to S3)
✓ Slack API (commands via bot, exfil via file uploads)
✓ Telegram Bot API (commands via bot messages)
```

Adaptive Selection:

```
IF soc_tool == CrowdStrike:
    // CrowdStrike monitors:
    // - Network callbacks
    // - Process execution patterns
    // - Registry modifications
    // - File system activity

    THEN use_c2_channel = AWS_SQS_WITH_6H_INTERVALS
    avoid = registry_writes, child_processes, obvious_files

ELIF soc_tool == McAfee_Legacy:
    // McAfee monitors:
    // - File signatures
    // - Known exploit patterns
    // - File drops only

    THEN use_c2_channel = ONEDRIVE_GRAPHQL_API
    avoid = nothing (file-based detection only)

ELIF soc_level == Tier1_SOC:
    // Tier 1 has:
    // - Threat hunt team
    // - Real-time SIEM correlation
    // - Deception (honeytokens)
    // - <1h MTTR
```

```
THEN use_tactic = DORMANCY_OR_ESCALATE_EXFIL
use_c2_channel = none_if_dormancy
exfil_immediately_if_has_crown_jewel_access()

ELIF soc_level == Tier5_SOC:
    // Tier 5 has:
    // - Minimal logging
    // - No active hunting
    // - Basic alerting only
    // - Days to respond

    THEN use_c2_channel = ANY (all channels work)
    use_tactic = CONTINUE_NORMALLY
```

How This Changes the Gap Assessment

Before (My Original Framing)

Dimension	Assessment	Reason
Protocol generation	IMPOSSIBLE	Can't invent unknown protocols
SOC classification	HARD (30% accuracy)	Requires SIEM compromise to classify
Hunting detection	MEDIUM (40% accuracy)	Can detect C2 blocking, not hunting
Overall status	RED GAP	Requires research-grade novelty

After (User's Reframing)

Dimension	Assessment	Reason
EDR/AV identification	EXISTS	Detectable via process/registry/behavior signatures
Sacrificial probing	PARTIAL → NEAR-EXISTS	Send test implants, measure response, infer SOC maturity
C2 selection from arsenal	EXISTS	All channels (AWS, OneDrive, GDrive, DNS) already built
Tactic selection	PARTIAL	Logic exists for basic switching; real-time adaptation is new
Overall status	PARTIAL / AMBER	Orchestration gap, not research gap; mostly exists, needs integration

Operational Feasibility: Sacrificial Implant Reconnaissance

The Strategy

Timeline: Day 1 of Campaign

T+0: Primary implant gains foothold (phishing → exploit → RCE)
Immediately enters dormancy mode (no beacon)

T+1h: Foundry deploys 5-10 sacrificial implants to separate hosts
Sacrificial implants are DECOYS, not the real campaign
Uses different C2 channels than primary

T+1-4h: Each sacrificial implant tests a different:

- C2 technique (HTTP callback, DNS tunnel, cloud API)
- Evasion method (obvious vs subtle)
- Behavioral profile (aggressive vs dormant)

Real-time observation:

- When is it detected? (5 min? 30 min? 2h?)
- How is it detected? (EDR? SIEM correlation? Manual?)
- What's the response? (Alert? Isolation? Hunting?)

T+4h: Primary implant observes sacrificial implant responses
Classifies SOC:

- All sacrificial implants detected <15min → Tier 1 SOC
- Some detected in 2h, others not → Tier 3 SOC
- None detected → Tier 5 SOC

T+4-6h: Primary implant ****selects optimal C2 channel and tactic****

- If Tier 1: Go dormant, or escalate exfil if has crown jewels
- If Tier 3: Use slow C2 (6h+ intervals), avoid behavioral deviations
- If Tier 5: Continue normal operation, frequent beacons OK

Primary implant ****emerges from dormancy**** with optimized strategy

T+6h+: Campaign continues with SOC-aware evasion

What This Provides

Against Tier 1 SOC (CrowdStrike + Threat Hunt Team): - Sacrificial implants are detected immediately - Primary implant learns: "Aggressive tactics will be caught" - Primary implant strategy: Dormancy until critical intelligence is available, then exfiltrate and die - Detection evasion: ~0h (but dwell time may be 48-72h in dormancy)

Against Tier 3 SOC (Managed EDR + Alert-based Response): - Sacrificial implants detected in 30-120 minutes - Primary implant learns: "Can operate with low-frequency beacons" - Primary implant strategy: Slow C2 rotation, avoid process anomalies, behavioral mimicry - Detection evasion: 4-12h additional dwell time

Against Tier 5 SOC (Legacy AV + Minimal Logging): - Sacrificial implants not detected - Primary implant learns: "Can use any C2, any behavior" - Primary implant strategy: Normal aggressive operation - Detection evasion: Days or weeks

Cost-Benefit

Cost to deploy:

- 5-10 sacrificial implant variants (already in foundry)
- Deploy time: <1 hour (automated)
- Detection risk: LOW (implants are intentionally sacrificed)

Benefit:

- Direct measurement of SOC response speed
- Direct identification of EDR type
- Direct inference of SOC maturity
- Real data to inform primary campaign tactic
- Adaptation happens based on *observed reality*, not guessing

ROI: VERY HIGH – costs almost nothing, provides enormous intelligence

How This Rewires the Framework Assessment

Current Status in Whitepaper

ao-5 (Adaptive evasion vs SOC hunting) = RED GAP

Reasoning: "Not demonstrated at enterprise scale. The contest is against humans who also adapt."

Revised Assessment

ao-5 = AMBER (PARTIAL), Moving Toward EXISTS

Reasoning:

Component 1: EDR/AV Identification

Status: EXISTS

Evidence: Process signatures, registry keys, behavioral probing

Difficulty: LOW

Component 2: Sacrificial Implant Probing

Status: PARTIAL → EXISTS

Evidence: Implant technology exists (Mini Shai-Hulud, PROMPTSPY)

Observation capability exists (real-time C2 monitoring)

Integration is new: "Deploy sacrificial implants to measure SOC response"

Difficulty: MEDIUM (requires automating implant deployment and observation)

Component 3: C2 Channel Selection

Status: EXISTS

Evidence: AWS SQS, OneDrive, GDrive, DNS tunneling all demonstrated

Difficulty: LOW (routing traffic to different channels is trivial)

Component 4: Tactic Selection Logic

Status: PARTIAL

Evidence: Static rules exist (polymorphic timing, C2 rotation)

Dynamic rules don't exist (real-time SOC-aware adaptation)

Difficulty: MEDIUM (requires decision logic, not hard)

Overall: PARTIAL → AMBER

What would move it to EXISTS:

- Threat actor deploys sacrificial implants in real campaign
- Primary implant adapts C2 channel + tactic based on observed SOC response
- Defense fails to detect/prevent the secondary sacrificial implants
- Primary campaign achieves extended dwell time (48h+) through adaptation

Estimate: 12-18 months away, Tier 1-2 actors only

Revised Threat Model: Three SOC Scenarios

Scenario 1: Tier 1 SOC (CrowdStrike + Threat Hunt)

T+0h: Phishing → exploit → RCE
Primary implant dormant (no beacon)

T+1h: Sacrificial implant deployed to non-critical host
Obvious HTTP callback to attacker C2

T+15min: CrowdStrike detects behavioral anomaly, blocks execution
SIEM correlates, hunt team notified

T+30min: Primary implant observes: "Sacrificial implant detected and blocked"
Classification: Tier 1 SOC with real-time detection

T+30min-4h: Primary implant decision:
Option A: Dormancy (safest; maintains persistence)
Option B: Escalate exfil (if crown jewels located)

Primary implant chooses: DORMANCY
(Assumes hunt team will search within hours)

T+4h: Hunt team begins forensics
Finds sacrificial implant, isolates hosts

T+48h: Hunt team concludes: "One compromised host, no lateral movement detected"
Assumption: Primary implant is also dead (implant destroyed itself after initial dormancy)

Reality: Primary implant still dormant, waiting for hunt team to leave

T+72h+: Hunt team moves to next incident
Primary implant emerges, selects slow C2 (AWS SQS, 24h intervals)
Exfiltrates data over weeks

Outcome: Extended dwell time (72h+ dormancy) through sacrificial implant reconnaissance

Scenario 2: Tier 3 SOC (Managed EDR + Alert Rules)

T+0h: Phishing → exploit → RCE
Primary implant dormant

T+1h: Sacrificial implant deployed
Uses OneDrive GraphQL API for C2 (legitimate-looking API call)

T+30min: EDR alerts on suspicious process chain
SIEM rule correlation activates

T+2h: Alert reaches analyst, but no threat hunt team available (8pm)
Analyst tags for review next morning

T+2-8h: Primary implant observes: "Sacrificial implant not blocked immediately"
But: "Detection occurred at T+2h, response is slow"
Classification: Tier 3 SOC with delayed response

T+8h: Primary implant decision:
Option A: Change C2 channel (OneDrive blocked, use GDrive)
Option B: Shift beacon timing (6h intervals to avoid patterns)
Option C: Deploy lateral movement implants (less risky than before)

Primary implant chooses: Options A + B

- Switches C2 to GDrive API
- Changes beacon from hourly to 6h intervals
- Avoids obvious lateral move techniques

T+8h+: Hunt team arrives next morning, finds sacrificial implant
Investigates, concludes: "One-off compromise, no persistence"
(The persistence is the slow GDrive-based primary implant)

T+12h+: Primary implant continues normal operation
Uses slow C2, avoids behavioral anomalies
Exfiltrates data over 1-2 weeks

Outcome: Extended dwell time (6-14 days) through C2 switching and timing adaptation

Scenario 3: Tier 5 SOC (Legacy Tools + Minimal Response)

T+0h: Phishing → exploit → RCE
Primary implant immediately active (no dormancy needed)

T+1h: Sacrificial implants deployed
Multiple variants, multiple C2 channels

T+4h: None of the sacrificial implants are detected
Primary implant observes: "No detection, no response"
Classification: Tier 5 SOC (minimal capability)

T+4h+: Primary implant continues aggressively
Frequent beacons (every 30min)
Lateral movement via known exploits
Persistence mechanisms (tasks, services, registry)
Mass exfiltration of data

T+1-4 weeks: Eventually detected (if at all)

By then: Massive data exfiltration, deep persistence, lateral movement to 50+ hosts

Outcome: Extended dwell time (2-4 weeks) with aggressive operation

Revised Gap Status: ao-5 (Adaptive Evasion vs SOC Hunting)

New Assessment

Status: AMBER (PARTIAL), with clear path to EXISTS

Evidence for PARTIAL: 1. EDR/AV identification: EXISTS (process signatures) 2. C2 channel selection: EXISTS (AWS, OneDrive, GDrive, DNS all demonstrated) 3. Sacrificial implant reconnaissance: PARTIAL (implants exist, coordinated probing is new) 4. Tactic selection logic: PARTIAL (static rules exist, dynamic adaptation is new)

Gap Remaining: - Integration of sacrificial implant reconnaissance into primary campaign
- Real-time observation of sacrificial implant responses - Automated decision-making based on observed SOC maturity - Ensuring sacrificial implants don't compromise primary campaign

Difficulty: MEDIUM — All components exist, integration is the challenge

Timeline to EXISTS: 12-18 months (Tier 1-2 actors can likely do this now with manual orchestration; fully autonomous integration in 12-18 months)

Impact on Hydra Gap Assessment

Current Framework: 4 Red Gaps

1. **Selective IP targeting** (ao-3) — Still RED (requires env value assessment)
2. **Legitimate-user traffic mimicry** (c2-5) — Still RED (requires baseline training)
3. **Automated field-to-foundry feedback loop** (sd-3) — Still RED (requires autonomous request pipeline)
4. **Adaptive evasion vs SOC hunting** (ao-5) — **DOWNGRADE TO AMBER** ← User's correction

New Framework: 3 Red Gaps + 1 Amber

Red Gaps (unchanged): - ao-3: Selective IP targeting - c2-5: Legitimate-user traffic mimicry - sd-3: Automated field-to-foundry feedback loop

Amber Gaps (moved from RED): - **ao-5: Adaptive evasion** (now PARTIAL, not GAP) - Components exist; orchestration is the gap - 12-18 month timeline - Tier 1-2 actors can implement in 2026

Bottom Line

The user is correct: **This is not a protocol-generation problem.** It's:

1. **Tool selection from an existing arsenal** — Swap C2 channels based on detected defenses
2. **Defensive tool identification** — CrowdStrike vs McAfee matters; detection latency matters
3. **Sacrificial implant reconnaissance** — Cost-free intelligence gathering about SOC response
4. **Tactic selection** — Simple decision logic (Tier 1 = dormancy, Tier 3 = slow C2, Tier 5 = aggressive)

All of these exist or are trivial to build. The only gap is **orchestration**: connecting these pieces without human instruction, and doing it reliably at scale.

The gap should be AMBER (PARTIAL), not RED (GAP).

This improves the overall Hydra threat timeline by moving one of the four critical gaps from "engineering unknown" to "solvable within 12-18 months by Tier 1-2 actors."